

Insecure string comparison (incomplete comparison) in _convert_from_str of descriptor.c #18993

✓ Closed

awen-li opened on May 12, 2021

Reproducing code example:

Snippet:

```
/* Check for a deprecated Numeric-style typecode */
/* `Uint` has deliberately weird uppercasing */
char *dep_tps[] = {"Bytes", "Datetime64", "Str", "Uint"};
int ndep_tps = sizeof(dep_tps) / sizeof(dep_tps[0]);
for (int i = 0; i < ndep_tps; ++i) {
    char *dep_tp = dep_tps[i];
    if (strncmp(type, dep_tp, strlen(dep_tp)) == 0) { -----> '\0' not considered
here, should be strlen(dep_tp)+1. (value of "type" may come from external modules)
        /* Deprecated 2020-06-09, NumPy 1.20 */
        if (DEPRECATE("Numeric-style type codes are "
                      "deprecated and will result in "
                      "an error in the future.") < 0) {
            goto fail;
        }
    }
}
```

Error message:

When we run our analysis tool on NumPy, an incomplete comparison problem was reported, see details below:

File: numpy/core/src/multiarray/descriptor.c

Function: _convert_from_str (line 1727 : 1740)

Optional call-path: PyArray_DescrAlignConverter -> _convert_from_any -> _convert_from_str

Details in [description](#)

NumPy/Python version information:

the main branch of NumPy

seberg on May 13, 2021

Member ...

I doubt it matters (its not like this is relevant for security or anything). But adding the `+1` would be good, also to avoid the slightly wrong things being copied.

 **seberg** added **00 - Bug** **component: num...** on May 13, 2021

 **awen-li** changed the title ~~Unsecure string comparison (incomplete comparison) in `_convert_from_str` of descriptor.c~~ Insecure string comparison (incomplete comparison) in `_convert_from_str` of descriptor.c on May 13, 2021

 NectDz on Jul 14, 2021

Contributor ...

Do you mind telling me the tool that was used to reproduce to get that error message?

 NectDz on Jul 14, 2021 · edited by seberg

Edits ▾ Contributor ...

1. Forked numpy and then cloned it
2. Ran python tests using "python3 runtests.py -v" and the build passed
3. The change I made was the following

```
diff --git a/numpy/core/src/multiarray/descriptor.c b/numpy/core/src/multiarray/descriptor.c
index 58aa608c3..f6202c7ea 100644
--- a/numpy/core/src/multiarray/descriptor.c
+++ b/numpy/core/src/multiarray/descriptor.c
@@ -1729,7 +1729,7 @@ _convert_from_str(PyObject *obj, int align)
     for (int i = 0; i < ndep_tps; ++i) {
         char *dep_tp = dep_tps[i];

-        if (strcmp(type, dep_tp, strlen(dep_tp)) == 0) {
+        if (strcmp(type, dep_tp, strlen(dep_tp)) + 1) {
             /* Deprecated 2020-06-09, NumPy 1.20 */
             if (DEPRECATE("Numeric-style type codes are "
                          "deprecated and will result in "
```

4. Ran the tests again and received the following error: **ERROR numpy/core/tests/test_regression.py - TypeError: data type 'int32' not understood**

Do you know where I might of gone wrong and why I am seeing this error?

 eric-wieser on Jul 14, 2021 · edited by eric-wieser

Edits ▾ Member ...

That change is nonsense, you removed the `==`.

2

 seberg on Jul 14, 2021

Member ...

You removed the `== 0`, that would invert the logic.

1



NectDz mentioned this [on Jul 22, 2021](#)

[DEP: Remove deprecated numeric style dtype strings #19539](#)



seberg closed this as [completed](#) in [eeef9d4](#) [on Aug 11, 2021](#)



scratchmex added a commit that references this issue [on Aug 13, 2021](#)

DEP: Remove deprecated numeric style dtype strings ([numpy#19539](#)) ...

bc3ffb2



rgommers modified the milestones: [1.21.0 release](#), [1.22.0 release](#) [on Dec 22, 2021](#)



anjaneya17 mentioned this [on Dec 29, 2021](#)

[Exclude transitive dependency from requirements.txt linkedin/pygradle#355](#)

42 remaining items

Load more



kandersolar mentioned this [on Jul 6, 2022](#)

[numpy 1.9.X security issue pvlb/pvanalytics#137](#)

bmerry on Jul 14, 2022 · edited by bmerry

Edits ▾

Contributor



From what I can see the original code was actually *correct*: it's checking whether `dep_tp` is a prefix of `type`, so that (for example) `UInt64` will be flagged as deprecated because it has `UInt` as a prefix:

```
>>> np.dtype("UInt64")
__main__:1: DeprecationWarning: Numeric-style type codes are deprecated and will result in an error in the future.
dtype('uint64')
```



So the proposals to add `+ 1` to the length would actually make the code wrong as it would prevent that `DeprecationWarning` from appearing. Not that it matters for future versions since the code has been removed, but that might be of interest for any OS distributions planning to "fix" older versions.



Ghostkeeper mentioned this [on Jul 26, 2022](#)

[Bump numpy from 1.21.5 to 1.22.0 Ultimaker/Uranium#838](#)

chtompki on Aug 17, 2022

I'm a tad confused by the lack of support for fixing this CVE? You've kinda left it hanging despite saying that 1.21 is supported until June 23, 2023. https://numpy.org/neps/nep-0029-deprecation_policy.html#drop-schedule

1

mattip on Aug 17, 2022

Member

@chtompki could you point to which part of the discussion above is confusing? I think the position of the NumPy team is quite clear. The process for disputing bogus CVEs is not transparent, we do not know why they have not withdrawn it.

1

chtompki on Aug 17, 2022 · edited by chtompki

Edits

Curious, I've always found the CVE process workable when I've written them. Who is your CVE Numbering Authority (CNA)? Is it the 501(c)(3) NumFOCUS or did you guys go through the request directly from MITRE? If you went directly through MITRE, then you may have to file an appeal: https://www.cve.org/ResourcesSupport/AllResources/CNARules#section_9_appeals_process

Also, let me know if there's anything I can do to help. Would love to, if possible.

seberg on Aug 17, 2022

Member

Curious, I've always found the CVE process workable when I've written them. Who is your CVE Numbering Authority (CNA)?

Well, nobody here has done this professional or even more than once. And maybe a point is that you are going through some CNA where the process surprisingly works easier?

We tried to tell MITRE that it is bogus, explaining why. They just asked for evidence without guidance how that would look like. So it is disputed, but that's it until someone explains how to "proof" that it is not a CVE.



chtompki mentioned this [on Aug 20, 2022](#)

✓ [numpy-1.21.6-cp37-cp37m-manylinux_2_12_x86_64.manylinux2010_x86_64.whl: 1 vulnerabilities \(highest severity is: 5.3\) capitalone/ablation#5](#)

chtompki on Aug 20, 2022

Hm....I would ask who applied for the CVE Number? Can we not go back to them and ask them to un-apply? If not then we need to appeal to MITRE through their process. I'd be happy to help with that if possible

rgommers on Aug 20, 2022

Member



Hm....I would ask who applied for the CVE Number? Can we not go back to them and ask them to un-apply? If not then we need to appeal to MITRE through their process. I'd be happy to help with that if possible

Probably @Daybreak2019 who opened this issue. But they seem like a known bad actor, lots of bogus CVEs and no response after that anymore (see [#18993 \(comment\)](#) above).

This is the problem with the whole security circus - no accountability from anyone (neither the CVE submitter nor MITRE), and we get left with this mess.

2



falkoschindler mentioned this [on Sep 7, 2022](#)

✓ [Security alert for NumPy<=1.21.6 zauberzeug/nicegui#67](#)



swryan mentioned this [on Oct 14, 2022](#)

🔗 [make python 3.7 the oldest in workflow, add ignore-vuln tadmiller/OpenMDAO#159](#)



jpn-- mentioned this [on Dec 13, 2022](#)

🔗 [Fix numpy ActivitySim/activitysim#584](#)



mroeschke mentioned this [on Jul 8, 2023](#)

✓ [Vulnerable dependency numpy for python < 3.11 pandas-dev/pandas#54036](#)



lesteve mentioned this [on Sep 23, 2025](#)

✓ [CVE-2024-34997 - False Positive? TL; DR yes, it is a false positive joblib/joblib#1588](#)

[Sign up for free](#) to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

00 - Bug

component: numpy_core

Type

No type

Projects

No projects

Milestone



1.22.0 release

Closed on Jan 6, 2022, 100% complete

Relationships

None yet

Development

 Code with agent mode



No branches or pull requests

Participants



+8